Задание 2
Локальное сканирование (CLI) 2
Trivy 2
Bandit 3
Сканирование через Docker 4
Trivy 4
Bandit 5
GitLab CI 6

Задание

Задача:

Для уязвимого проекта django.nv:

1. Протестировать работу trivy и bandit локально:

- установить инструмент, запустить сканирование из CLI, получить отчет в формате json
- скачать docker-образ инструмента, запустить сканирование, получить отчет в формате json

2. Создать пайплайн из трех стейджей build, test, prod.

- Встроить на стейдже build инструмент trivy. Должно проводиться сканирование файловой системы с сохранением отчета в формате json.
- Встроить на стейдже test инструмент bandit, провести сканирование кода с фильтром уязвимостей от среднего уровня и выше. Отчет сканирования должен сохраняться в формате json.
- Общие требования: job не должны останавливать работу pipeline, отчеты, полученные в ходе job, должны быть сохранены в виде артефакта работы.

Формат выполнения: отчет в формате PDF, который содержит скриншоты команд и результатов работы при запуске инструментов в CLI, в виде докер-образа и в CI/CD, а также финальный код итогового pipeline.

Локальное сканирование (CLI)

Trivy

Запуск Trivy

```bash

trivy fs . --format json --output trivy-report.json

*fs - указание на файловую систему*

*. - путь к репо*

*--format - задает формат*
```

--output - *вывод в файл*

```

# Bandit

Запуск Bandit

```bash

bandit -r . -f json -o bandit-report.json

*-r - рекурсивный обход всех вложенных папок*

*-f задает формат*

*-o - вывод в файл*

```

```

```
(base) sapman@Mac-mini-sapman django.nV % tail -50 bandit-report.json
      "line_range": [
        184,
        185
      ],
      "more_info": "https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html",
      "test_id": "B608",
      "test_name": "hardcoded_sql_expressions"
    },
    {
      "code": "750   userprofile.reset_token_expiration = timezone.now()\n751   userprofile.reset_token = ''\n752   userprofile.sa
ve()\n",
      "col_offset": 42,
      "end_col_offset": 44,
      "filename": "./taskManager/views.py",
      "issue_confidence": "MEDIUM",
      "issue_cwe": {
        "id": 259,
        "link": "https://cwe.mitre.org/data/definitions/259.html"
      },
      "issue_severity": "LOW",
      "issue_text": "Possible hardcoded password: ''",
      "line_number": 751,
      "line_range": [
        751
      ],
      "more_info": "https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html",
      "test_id": "B105",
      "test_name": "hardcoded_password_string"
    },
    {
      "code": "766   userprofile.user.set_password(new_password)\n767   userprofile.reset_token = ''\n768   userprofile.reset_token_expiration = timezone.
now()\n",
      "col_offset": 34,
      "end_col_offset": 36,
      "filename": "./taskManager/views.py",
      "issue_confidence": "MEDIUM",
      "issue_cwe": {
        "id": 259,
        "link": "https://cwe.mitre.org/data/definitions/259.html"
      },
      "issue_severity": "LOW",
      "issue_text": "Possible hardcoded password: ''",
      "line_number": 767,
      "line_range": [
        767
      ],
      "more_info": "https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html",
      "test_id": "B105",
      "test_name": "hardcoded_password_string"
    }
  ]
```

Сканирование через Docker

Trivy

Скачивание и запуск официального образа, монтируем текущую папку $(pwd) внутрь контейнера в /app

Версия для arm-процессора (Apple Silicone)

```bash

docker run --rm -v "$(pwd):/app" aquasec/trivy:0.69.3-arm64 fs /app --format json --output /app/trivy-docker-report.json

```

```
(base) sapman@Mac-mini-sapman django.nV %
(base) sapman@Mac-mini-sapman django.nV % docker run --rm -v "$(pwd):/app" aquasec/trivy:0.69.3-arm64 fs /app --format json --output /app/trivy-docker-report.json

Unable to find image 'aquasec/trivy:0.69.3-arm64' locally
0.69.3-arm64: Pulling from aquasec/trivy
d8ad8cd72600: Already exists
95841b475c1b: Pull complete
15e23908324b: Pull complete
afb5f192254f: Pull complete
Digest: sha256:532de2ce287f594fbfbd91853c6d0910517cc87b01501b73b358b3d31b4eb87c
Status: Downloaded newer image for aquasec/trivy:0.69.3-arm64
2026-04-01T15:28:31Z    INFO    [vulndb] Need to update DB
2026-04-01T15:28:31Z    INFO    [vulndb] Downloading vulnerability DB...
2026-04-01T15:28:31Z    INFO    [vulndb] Downloading artifact...        repo="mirror.gcr.io/aquasec/trivy-db:2"
255.25 KiB / 89.19 MiB [>_____________________________________________________] 0.28% ? p/s ?815.20 KiB / 89.19 MiB [>_____________________________________________________]
_____________] 0.89% ? p/s ?1.64 MiB / 89.19 MiB [->____________________________________________________] 1.84% ? p/s ?4.03 MiB / 89.19 MiB [-->___________________________________________________]
_____________________________] 4.52% 6.31 MiB p/s ETA 13s5.08 MiB / 89.19 MiB [-->_____________________________________________________] 5.69% 6.31 MiB p/s ETA 13s6.23 MiB / 89.19
 MiB [--->____________________________________________________] 6.99% 6.31 MiB p/s ETA 13s6.94 MiB / 89.19 MiB [--->____________________________________________________] 7.78% 6.22 MiB
 p/s ETA 13s8.55 MiB / 89.19 MiB [---->___________________________________________________] 9.58% 6.22 MiB p/s ETA 12s9.69 MiB / 89.19 MiB [----->__________________________________________________
___________] 10.86% 6.22 MiB p/s ETA 12s11.02 MiB / 89.19 MiB [----->__________________________________________________] 12.35% 6.26 MiB p/s ETA 12s11.84 MiB / 89.19 MiB [------>_________________________________________
_____________________________________] 13.28% 6.26 MiB p/s ETA 12s13.12 MiB / 89.19 MiB [------->_________________________________________________] 14.72% 6.26 MiB p/s ETA 12s13.9
8 MiB / 89.19 MiB [------->_________________________________________] 15.68% 6.17 MiB p/s ETA 12s14.50 MiB / 89.19 MiB [------->_________________________________________________] 16.
26% 6.17 MiB p/s ETA 12s14.50 MiB / 89.19 MiB [------->_________________________________________] 16.26% 6.17 MiB p/s ETA 12s15.84 MiB / 89.19 MiB [-------->________________________________________
_____________________________] 17.76% 5.97 MiB p/s ETA 12s16.58 MiB / 89.19 MiB [-------->_________________________________________] 18.59% 5.97 MiB p/s ETA 12s17.23 MiB / 89.19 Mi
B [--------->________________________________________] 19.32% 5.97 MiB p/s ETA 12s17.77 MiB / 89.19 MiB [--------->________________________________________] 19.92% 5.79 MiB p/s
 ETA 12s18.52 MiB / 89.19 MiB [--------->________________________________________] 20.76% 5.79 MiB p/s ETA 12s19.12 MiB / 89.19 MiB [---------->_______________________________________
_____________] 21.44% 5.79 MiB p/s ETA 12s19.72 MiB / 89.19 MiB [---------->_________________________________________] 22.11% 5.63 MiB p/s ETA 12s20.45 MiB / 89.19 MiB [----------->______________________________________
_____________________________] 22.93% 5.63 MiB p/s ETA 12s20.87 MiB / 89.19 MiB [----------->_________________________________________] 23.41% 5.63 MiB p/s ETA 12s21.59 Mi
B / 89.19 MiB [----------->_________________________________________] 24.21% 5.47 MiB p/s ETA 12s21.70 MiB / 89.19 MiB [----------->_________________________________________] 24.33%
5.47 MiB p/s ETA 12s22.78 MiB / 89.19 MiB [------------>________________________________________] 25.54% 5.47 MiB p/s ETA 12s23.87 MiB / 89.19 MiB [------------>________________________________________
_____________] 26.77% 5.36 MiB p/s ETA 12s24.42 MiB / 89.19 MiB [------------>________________________________________] 27.38% 5.36 MiB p/s ETA 12s25.05 MiB / 89.19 MiB [-
------------>________________________________________] 28.08% 5.36 MiB p/s ETA 11s25.61 MiB / 89.19 MiB [------------>________________________________________] 28.71% 5.20 MiB p/s ETA
 12s26.09 MiB / 89.19 MiB [------------>________________________________________] 29.26% 5.20 MiB p/s ETA 12s26.42 MiB / 89.19 MiB [------------>________________________________________
___] 29.62% 5.20 MiB p/s ETA 12s27.06 MiB / 89.19 MiB [------------>________________________________________] 30.34% 5.02 MiB p/s ETA 12s27.72 MiB / 89.19 MiB [------------>________________________________________
_____________] 31.08% 5.02 MiB p/s ETA 12s28.44 MiB / 89.19 MiB [------------>________________________________________] 31.88% 5.02 MiB p/s ETA 12s28.83 MiB /
89.19 MiB [------------>________________________________________] 32.32% 4.89 MiB p/s ETA 12s29.52 MiB / 89.19 MiB [------------>________________________________________] 33.09% 4.89
 MiB p/s ETA 12s30.14 MiB / 89.19 MiB [------------>________________________________________] 33.79% 4.89 MiB p/s ETA 12s30.64 MiB / 89.19 MiB [------------>________________________________________
_____________] 34.36% 4.77 MiB p/s ETA 12s31.34 MiB / 89.19 MiB [------------>________________________________________] 35.14% 4.77 MiB p/s ETA 12s31.86 MiB / 89.19 MiB [------
------------>________________________________________] 35.72% 4.77 MiB p/s ETA 12s32.42 MiB / 89.19 MiB [------------>________________________________________] 36.35% 4.65 MiB p/s ETA 12s
33.11 MiB / 89.19 MiB [------------>________________________________________] 37.12% 4.65 MiB p/s ETA 12s33.50 MiB / 89.19 MiB [------------>________________________________________]
 37.56% 4.65 MiB p/s ETA 11s34.39 MiB / 89.19 MiB [------------>________________________________________] 38.56% 4.56 MiB p/s ETA 12s34.97 MiB / 89.19 MiB [------------>________________________________________
_____________] 39.21% 4.56 MiB p/s ETA 11s35.64 MiB / 89.19 MiB [------------>________________________________________] 39.96% 4.56 MiB p/s ETA 11s36.00 MiB / 89.1
9 MiB [------------>________________________________________] 40.36% 4.44 MiB p/s ETA 11s36.70 MiB / 89.19 MiB [------------>________________________________________] 41.15% 4.44 MiB
 p/s ETA 11s37.31 MiB / 89.19 MiB [------------>________________________________________] 41.84% 4.44 MiB p/s ETA 11s37.95 MiB / 89.19 MiB [------------>________________________________________
_____________] 42.55% 4.36 MiB p/s ETA 11s38.31 MiB / 89.19 MiB [------------>________________________________________] 42.96% 4.36 MiB p/s ETA 11s39.00 MiB / 89.19 MiB [------------
------------>________________________________________] 43.73% 4.36 MiB p/s ETA 11s39.39 MiB / 89.19 MiB [------------>________________________________________] 44.17% 4.24 MiB p/s ETA 11s40.0
6 MiB / 89.19 MiB [------------>________________________________________] 44.92% 4.24 MiB p/s ETA 11s40.70 MiB / 89.19 MiB [------------>________________________________________] 45.
64% 4.24 MiB p/s ETA 11s41.05 MiB / 89.19 MiB [------------>________________________________________] 46.02% 4.14 MiB p/s ETA 11s41.73 MiB / 89.19 MiB [------------>________________________________________
_____________] 46.79% 4.14 MiB p/s ETA 11s42.28 MiB / 89.19 MiB [------------>________________________________________] 47.41% 4.14 MiB p/s ETA 11s42.77 MiB / 89.19 Mi
B [------------>________________________________________] 47.95% 4.06 MiB p/s ETA 11s43.55 MiB / 89.19 MiB [------------>________________________________________] 48.83% 4.06 MiB p/s
 ETA 11s44.17 MiB / 89.19 MiB [------------>________________________________________] 49.53% 4.06 MiB p/s ETA 11s44.94 MiB / 89.19 MiB [------------>________________________________________
```

```
django.nV — -zsh — 172×57
2026/04/01 18:29:
------------>____] 90.54% 3.82 MiB p/s ETA 2s81.08 MiB / 89.19 MiB [------------>____] 90.91% 3.82 MiB p/s ETA 2s81.55 Mi
B / 89.19 MiB [------------>____] 91.43% 3.82 MiB p/s ETA 1s82.03 MiB / 89.19 MiB [------------>____] 91.96%
 3.71 MiB p/s ETA 1s82.06 MiB / 89.19 MiB [------------>____] 92.01% 3.71 MiB p/s ETA 1s82.69 MiB / 89.19 MiB [------------
------------>____] 92.71% 3.71 MiB p/s ETA 1s83.12 MiB / 89.19 MiB [------------>____] 93.20% 3.59 MiB p/s ETA 1s83.47 MiB / 89.19 MiB [-
------------>____] 93.59% 3.59 MiB p/s ETA 1s84.42 MiB / 89.19 MiB [------------>____] 94.66% 3.59 MiB p/s ET
A 1s84.97 MiB / 89.19 MiB [------------>____] 95.27% 3.56 MiB p/s ETA 1s85.52 MiB / 89.19 MiB [------------
->____] 95.80% 3.56 MiB p/s ETA 1s86.20 MiB / 89.19 MiB [------------>____] 96.74% 3.56 MiB p/s ETA 0s86.69 MiB / 89.19 MiB [------------
------------>____] 97.20% 3.51 MiB p/s ETA 0s87.28 MiB / 89.19 MiB [------------>____] 97.86% 3.51 MiB p/s ETA 0s87.70 MiB /
89.19 MiB [------------>____] 98.34% 3.51 MiB p/s ETA 0s88.17 MiB / 89.19 MiB [------------>____] 98.868 3.4
5 MiB p/s ETA 0s88.58 MiB / 89.19 MiB [------------>____] 99.32% 3.45 MiB p/s ETA 0s88.98 MiB / 89.19 MiB [------------
------------>____] 99.77% 3.45 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 3.33 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [-----
------------>____] 100.00% 3.33 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 3.33 MiB p/s ETA 0s
89.19 MiB / 89.19 MiB [------------>____] 100.00% 3.12 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>]
 100.00% 3.12 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 3.12 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------
------------>____] 100.00% 2.92 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 2.92 MiB p/s ETA 0s89.19 MiB / 89.1
9 MiB [------------>____] 100.00% 2.92 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 2.73 Mi
B p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 2.73 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------
------------>____] 100.00% 2.73 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 2.55 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [-----
------------>____] 100.00% 2.55 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 2.55 MiB p/s ETA 0s89.1
9 MiB / 89.19 MiB [------------>____] 100.00% 2.39 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100
.00% 2.39 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 2.39 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 2.23 MiB p/s ETA 0s89.19 MiB / 89.19 Mi
B [------------>____] 100.00% 2.23 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 2.23 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 2.09 MiB p/
s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 2.09 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 2.09 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [-----
------------>____] 100.00% 2.09 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.95 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------
------------>____] 100.00% 1.95 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.95 MiB p/s ETA 0s89.19 Mi
B / 89.19 MiB [------------>____] 100.00% 1.83 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00%
1.83 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.83 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------
------------>____] 100.00% 1.71 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.71 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [-
------------>____] 100.00% 1.71 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.60 MiB p/s ET
A 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.60 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------
-->____] 100.00% 1.60 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.50 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------
------------>____] 100.00% 1.50 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.50 MiB p/s ETA 0s89.19 MiB /
89.19 MiB [------------>____] 100.00% 1.40 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.4
0 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.40 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [-----
------------>____] 100.00% 1.31 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.31 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [-----
------------>____] 100.00% 1.31 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.23 MiB p/s ETA 0s
89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.23 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>]
 100.00% 1.23 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.15 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------
------------>____] 100.00% 1.15 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.15 MiB p/s ETA 0s89.19 MiB / 89.1
9 MiB [------------>____] 100.00% 1.07 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.07 Mi
B p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.07 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [-----
------------>____] 100.00% 1.00 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 1.00 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [-----
------------>____] 100.00% 1.00 MiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 961.00 KiB p/s ETA 0s89.1
9 MiB / 89.19 MiB [------------>____] 100.00% 961.00 KiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.0
0% 961.00 KiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 899.07 KiB p/s ETA 0s89.19 MiB / 89.19 MiB [------
------------>____] 100.00% 899.07 KiB p/s ETA 0s89.19 MiB / 89.19 MiB [------------>____] 100.00% 899.07 KiB p/s ETA 0s89.19 MiB / 89.19 Mi
B [------------>____] 100.00% 2.37 MiB p/s ETA 38s2026-04-01T15:29:10Z    INFO    [vulndb] Artifact successfully downloaded       repo="mirror
.gcr.io/aquasec/trivy-db:2"
2026-04-01T15:29:10Z    INFO    [vuln] Vulnerability scanning is enabled
2026-04-01T15:29:10Z    INFO    [secret] Secret scanning is enabled
2026-04-01T15:29:10Z    INFO    [secret] If your scanning is slow, please try '--scanners vuln' to disable secret scanning
2026-04-01T15:29:10Z    INFO    [secret] Please see https://trivy.dev/docs/v0.69/guide/scanner/secret#recommendation for faster secret detection
2026-04-01T15:29:12Z    WARN    [pip] Unable to find python `site-packages` directory. License detection is skipped.     err="unable to find path to Python executable"
2026-04-01T15:29:12Z    INFO    Number of language-specific files       num=1
2026-04-01T15:29:12Z    INFO    [pip] Detecting vulnerabilities...
(base) sapman@Mac-mini-sapman django.nV %
```

```
trivy-docker-report.json                                   Открыть в приложении «Visual Studio Code»
{
  "type": "pip",
  "Packages": [
    {
      "Name": "Django",
      "Identifier": {
        "PURL": "pkg:pypi/django@1.8.3",
        "UID": "f0286cde5029df33"
      },
      "Version": "1.8.3",
      "Locations": [
        {
          "StartLine": 1,
          "EndLine": 1
        }
      ],
      "AnalyzedBy": "pip"
    }
  ],
  "Vulnerabilities": [
    {
      "VulnerabilityID": "CVE-2016-9013",
      "VendorIDs": [
        "GHSA-mv8g-fhh6-6267"
      ],
      "PkgName": "Django",
      "PkgIdentifier": {
        "PURL": "pkg:pypi/django@1.8.3",
        "UID": "f0286cde5029df33"
      },
      "InstalledVersion": "1.8.3",
      "FixedVersion": "1.10.3, 1.9.11, 1.8.16",
      "Status": "fixed",
      "SeveritySource": "ghsa",
      "PrimaryURL": "https://avd.aquasec.com/nvd/cve-2016-9013",
      "DataSource": {
        "ID": "ghsa",
        "Name": "GitHub Security Advisory pip",
        "URL": "https://github.com/advisories?query=type%3Areviewed+ecosystem%3Apip"
      },
      "Fingerprint": "sha256:fb31c332c1cafeffd9d7225e3baa4d67720075 6ec4e83d7da82a95f2ae1cf12c",
      "Title": "python-django: user with hardcoded password created when running tests on Oracle",
      "Description": "Django 1.8.x before 1.8.16, 1.9.x before 1.9.11, and 1.10.x before 1.10.3 use a hardcoded password for
a temporary database user created when running tests with an Oracle database, which makes it easier for remote attackers to
obtain access to the database server by leveraging failure to manually specify a password in the database settings TEST
dictionary.",
      "Severity": "CRITICAL",
      "CweIDs": [
        "CWE-798"
      ],
      "VendorSeverity": {
        "ghsa": 4,
        "nvd": 4,
        "redhat": 2,
        "ubuntu": 2
      },
      "CVSS": {
        "ghsa": {
          "V3Vector": "CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H",
          "V40Vector": "CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N",
          "V3Score": 9.8,
          "V40Score": 9.3
        },
        "nvd": {
          "V2Vector": "AV:N/AC:L/Au:N/C:P/I:P/A:P",
          "V3Vector": "CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H",
          "V2Score": 7.5,
          "V3Score": 9.8
        },
        "redhat": {
          "V2Vector": "AV:N/AC:H/Au:N/C:P/I:P/A:N",
          "V3Vector": "CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N",
          "V2Score": 4,
          "V3Score": 7.4
```

Bandit

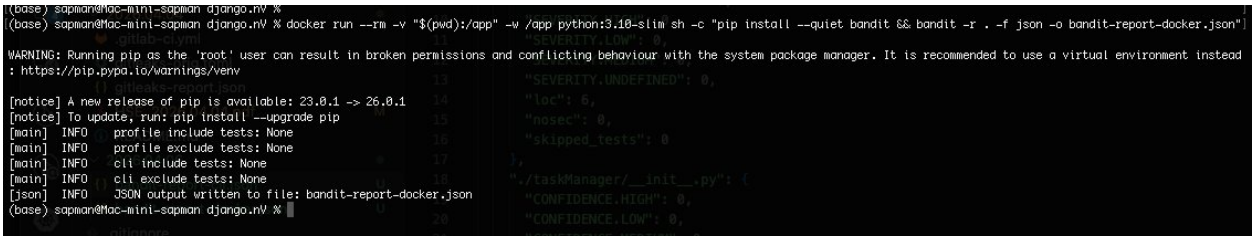
Скачивание и запуск официального образа, монтируем текущую папку $(pwd) внутрь контейнера в /app

Версия для arm-процессора (Apple Silicone)

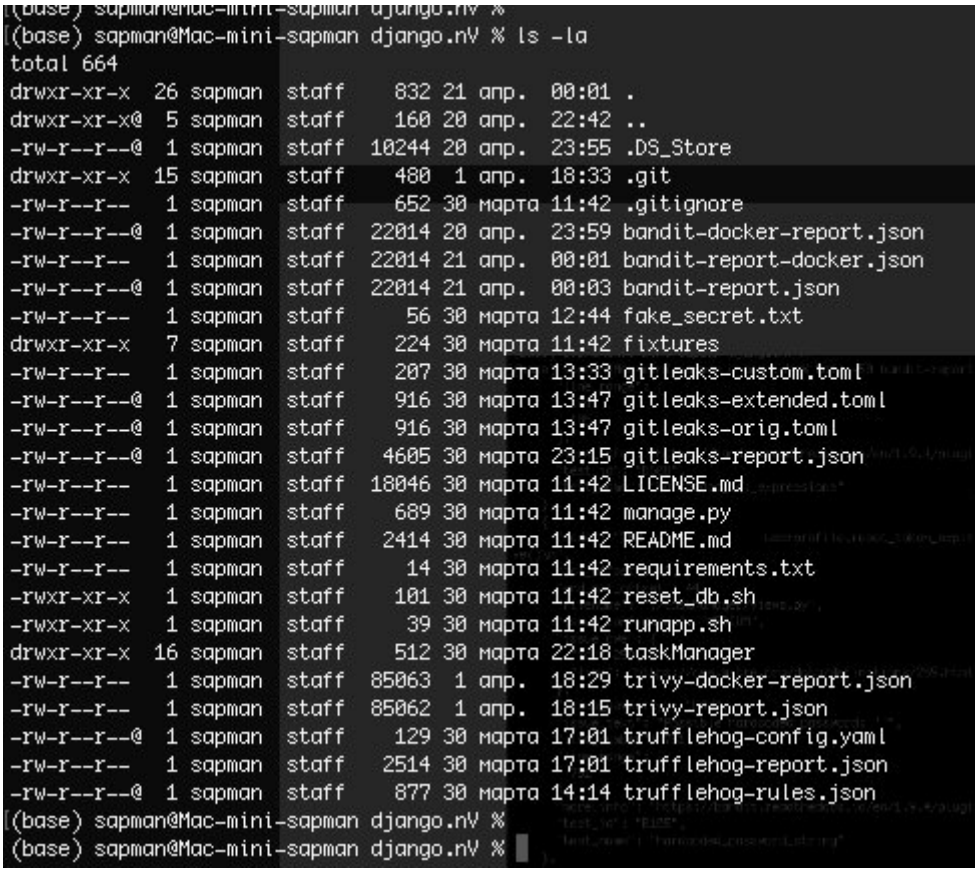
```bash
```

docker run --rm -v "$(pwd):/app" aquasec/trivy:0.69.3-arm64 fs /app --format json --output /app/trivy-docker-report.json

```




Проверка структуры локальной копии репо:




# GitLab CI

Содержимое файла пайплайна

```bash

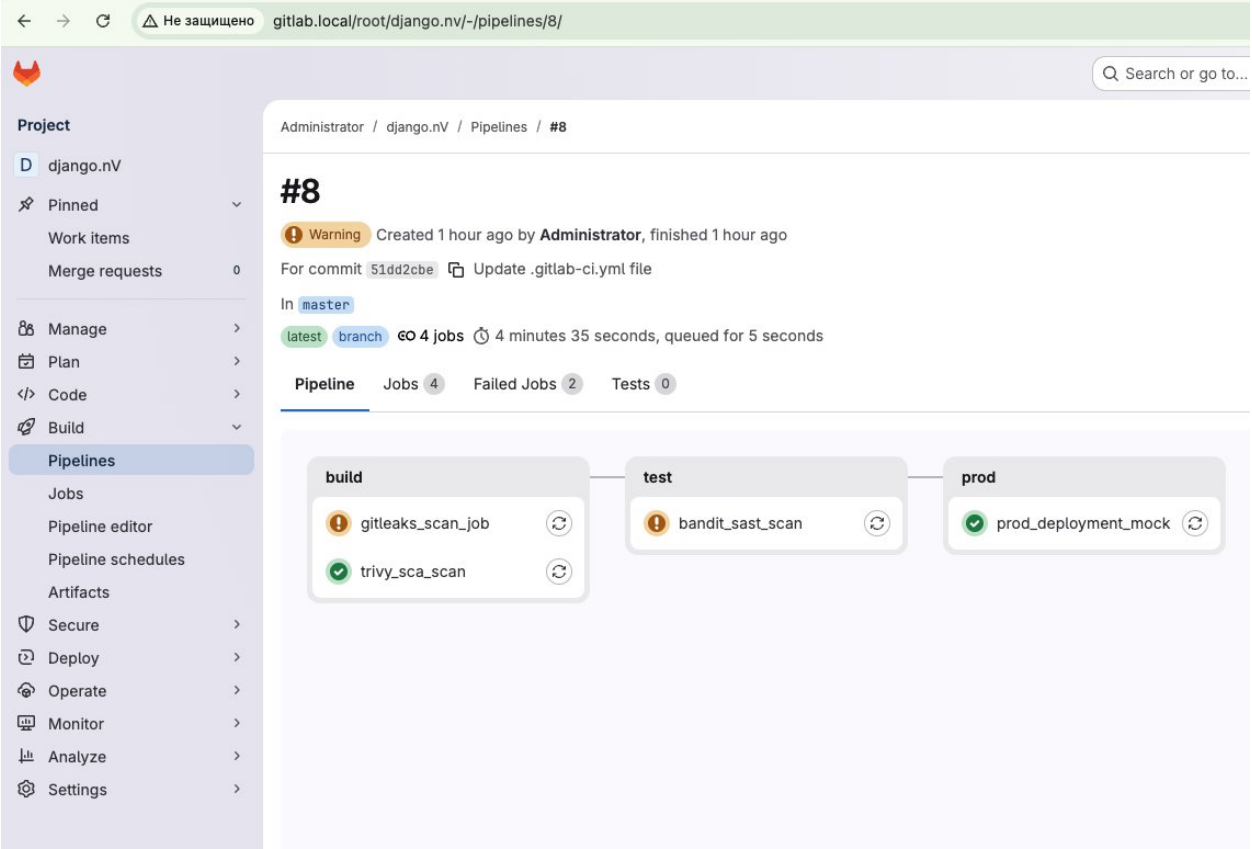
# ----------

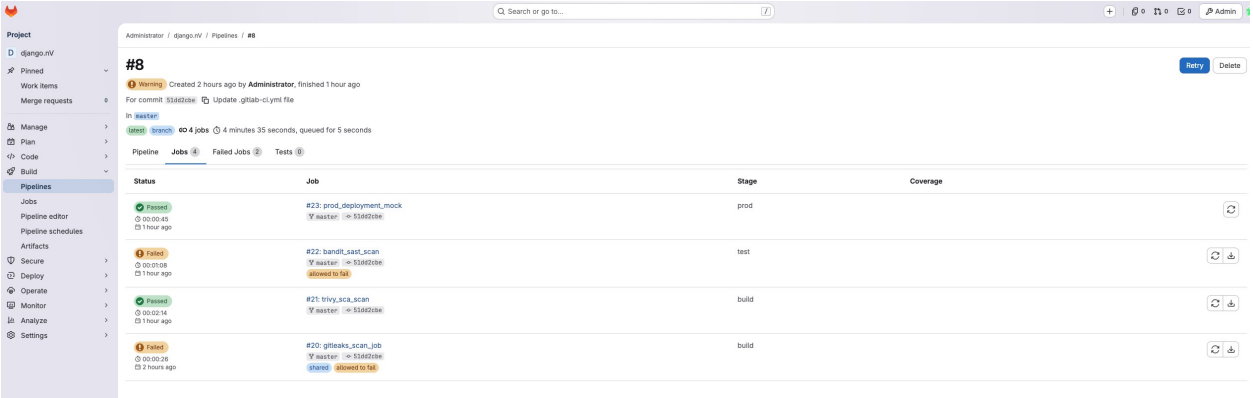
```yaml
# STAGES
# ---------------------------------------------------------
stages:
  - build
  - test
  - prod
# ---------------------------------------------------------
# STAGE: BUILD (SCA)
# ---------------------------------------------------------
gitleaks_scan_job:
  stage: build
  tags:
    - shared
  image:
    name: zricethezav/gitleaks:latest
    entrypoint: [""]
  script:
    - echo "Сканирования Secret Detection by Gitleaks..."
    - gitleaks detect --no-git -v --config gitleaks-orig.toml --report-format json --report-path gitleaks-report.json
  artifacts:
    paths:
      - gitleaks-report.json
    when: always
    expire_in: 1 week
  allow_failure: true


trivy_sca_scan:
  stage: build
  image:
    name: aquasec/trivy:latest
    entrypoint: [""]
```

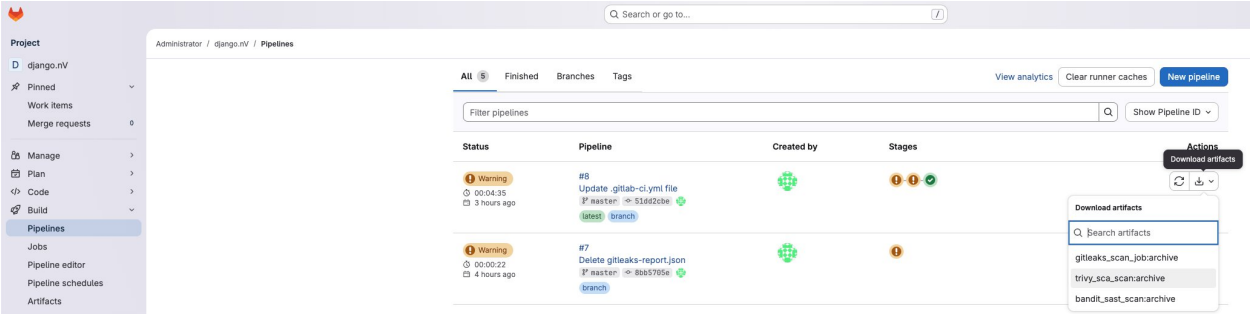
```yaml
  script:
    - echo "Запуск SCA-сканирования через Trivy..."
    - trivy fs . --format json --output trivy-report.json
  # Продолжаеть работу пайплайна при нахождении уязвимостей (требование к заданию)
  allow_failure: true
  artifacts:
    paths:
      - trivy-report.json
    # Сохраняет артефакт всегда (требование к заданию)
    when: always
    expire_in: 1 week
# ------------------------------------------------------------
# STAGE: TEST (SAST)
# ------------------------------------------------------------
bandit_sast_scan:
  stage: test
  image: python:3.10-slim
  script:
    - echo "Установка и запуск SAST-сканера Bandit..."
    - pip install --quiet bandit
    # Флаг -ll фильтрует уязвимости (оставляет только от Medium и выше)
    # Флаг -r запускает рекурсивный поиск по директории
    - bandit -r . -ll -f json -o bandit-report.json
  allow_failure: true
  artifacts:
    paths:
      - bandit-report.json
    when: always
    expire_in: 1 week
# ------------------------------------------------------------
# STAGE: PROD
```

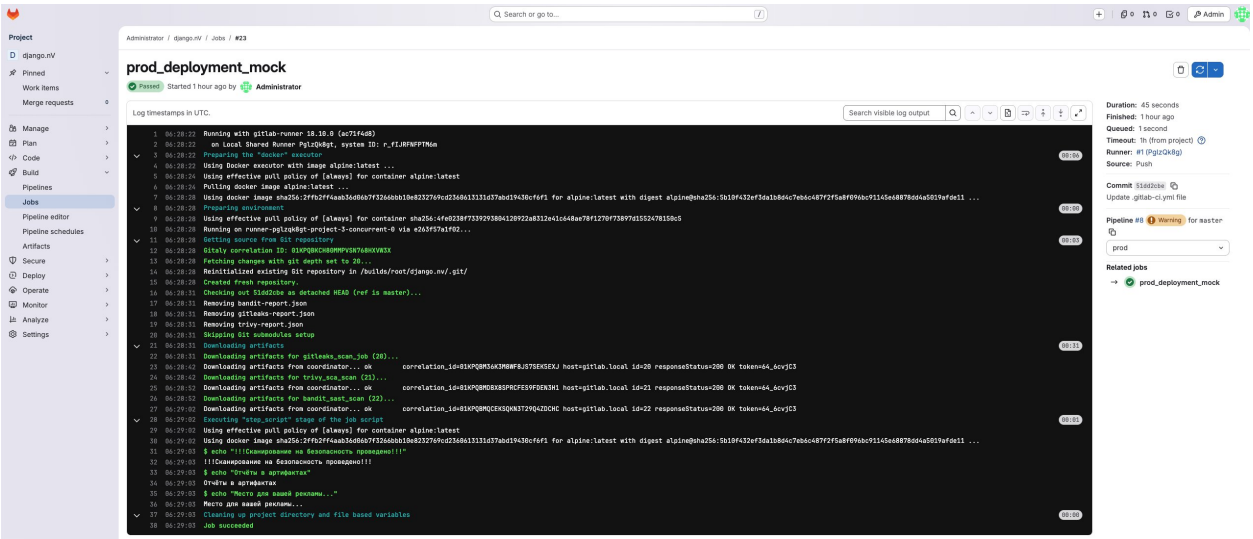
```
# ----------------------------------------------------------

prod_deployment_mock:

  stage: prod

  image: alpine:latest

  script:

    - echo "!!!Сканирование на безопасность проведено!!!"

    - echo "Отчёты в артифактах"

    - echo "Место для вашей рекламы..."
```

Скрин с выполнением шагов. Намеренно оставил шаг «gitleaks_scan_job» из предыдущего задания для более детального понимания процесса.









Все коммиты можно найти в личном пространстве

https://github.com/sapsolman/netology-hse